

Evidence-Grounded Local Language Models and Behavioral Telemetry for Defensive Network Review

João Vitor Ielen and Vinicius Mota Favaro
 Centro Universitário UniOpet, Curitiba, Paraná, Brazil
 Academic advisor: Michel Cesar dos Santos

Abstract

Security telemetry contains observable events, not proof of compromise. This study asks whether local language models can prioritize transparent behavioral findings while preserving evidence boundaries and withholding response authority. The artifact correlates authorized Nmap inventory with normalized telemetry, applies four auditable rules, assigns stable evidence identifiers, and validates schema-constrained output deterministically. Evaluation combines inert fixtures, family-separated CTU-13 sources, a synthetic implementation-transfer source, a 180-call three-model/three-prompt matrix, adversarial pairs, and component ablations. The inert benchmark reached F1 0.889. An inspected NSIS.ay holdout reached F1 0.317 and a Matthews correlation coefficient (MCC) of -0.282; a prospectively frozen DonBot holdout reached F1 0.600 and MCC 0.452. On NSIS.ay, block-on-alert would have acted on 32 normal windows and missed 37 botnet windows. A single-model comparison retained exact identifiers in 50/50 grounded calls and 0/50 reconstructed free-text calls. In the broader matrix, 145/180 calls received responses and 73 passed deterministic validation; 35 Qwen attempts failed after the local server exited. Removing the API format constraint yielded no valid JSON in 12 calls. Among 11 adversarial pairs with both responses, validator status changed in eight. These results justify model-assisted triage only when deterministic checks remain in control. They do not support autonomous attribution or containment.

Index Terms

network telemetry, local language model, behavioral detection, CTU-13, defensive automation

1. Introduction

Network discovery and operating-system telemetry describe different layers of a security event. Nmap can identify reachable hosts, open ports, and uncertain service fingerprints [1], [2]; endpoint telemetry can associate connections, DNS queries, and file creation with processes [3]. Neither source alone establishes that software is malicious or that a vulnerability is exploitable. Those conclusions require provenance, context, and independent validation.

Large language models (LLMs) can organize evidence and make technical output easier to review, but fluent text can also erase the distinction between an observation and a conclusion. Local inference reduces disclosure to external services, not epistemic risk. The NIST AI Risk Management Framework emphasizes governance, measurement, and continued risk management instead of treating model output as self-validating [4].

The starting point was an undergraduate project approved in 2025. That system parsed authorized Nmap XML, produced reports, optionally requested local Ollama narratives, and proposed future firewall integration. The current implementation narrows and tests that idea. Deterministic code owns observations and rule matches, the LLM may prioritize only supplied findings, and every disruptive action remains outside the model trust boundary.

The study asks three questions. RQ1: how do frozen transparent behavior rules perform on inert functional fixtures and on independently labeled external flows? RQ2: can a schema-constrained local LLM preserve exact evidence traceability compared with the reconstructed 2025 free-text protocol? RQ3: which defensive actions are justified before malicious activity is independently confirmed?

The contributions are: (1) a normalized telemetry schema with stable evidence identifiers; (2) four auditable behavior rules with explicit non-confirmation fields; (3) a loopback-only LLM protocol whose citations and controls are deterministically validated; (4) a streaming CTU-13 adapter with frozen provenance and

family-separated holdout; (5) multi-model, prompt-variant, adversarial and ablation evaluations that preserve availability and policy failures; and (6) retained negative results that quantify why neither alerts nor model narratives should directly trigger containment.

2. Foundations and Evidence Boundary

A. From scan observations to behavioral review

An open port is an endpoint, not a confirmed vulnerability. Product identity, affected version, configuration, reachability, authentication, and compensating controls determine its security significance. Similarly, periodic traffic, rapid contact with distinct endpoints, and asymmetric byte counts are dual-use patterns. Routine software updates, browsers, backups, monitoring, and authorized administration can exhibit them.

MITRE ATT&CK documents behaviors such as application-layer command traffic, network service discovery, exfiltration over an existing channel, and ingress tool transfer [5]. These techniques provide analytical context for the rules. A match is labeled behavior-review; it does not assert that an ATT&CK technique, malware family, compromise, or exploitable vulnerability occurred.

The external corpus is CTU-13, a set of thirteen scenarios containing labeled botnet, normal, and background network traffic [6], [7]. The publisher warns that inbound To-Botnet traffic is not necessarily malicious. This study therefore scores only source-origin From-Botnet and From-Normal records and excludes background and all To-* labels.

B. Grounded local inference

Ollama supports local inference and JSON-schema structured outputs [8], [9]. A schema can constrain representation, but it cannot prove semantic correctness. The implemented validator consequently checks that every cited finding and event identifier existed in the supplied evidence, rejects unsupported CVEs and absolute compromise claims, requires complete finding coverage, and permits only controls pre-mapped to each transparent rule.

The system preserves five states: Nmap observation, normalized event, deterministic rule match, LLM prioritization, and independent analyst conclusion. No earlier state may be presented as a later one. Every finding explicitly denies confirmed malware and vulnerability and denies authorization for automatic response.

3. Related Work and Positioning

Network anomaly detection has long faced a gap between closed-world evaluation and operational deployment. Sommer and Paxson identify high error costs, a semantic gap between alerts and operational meaning, variable benign traffic, evaluation difficulties, and adversarial conditions [10]. Buczak and Guven catalog the broad range of data-mining and machine-learning methods applied to intrusion detection [11]; that methodological breadth does not remove the deployment constraints identified by Sommer and Paxson. CTU-13 supplies labeled botnet, normal, and background flows and has supported many botnet classifiers [6]; however, a family label is not proof that every source-window contains a rule-observable malicious action. The family-separated holdout is therefore used as a stress test of fixed review heuristics, not as evidence of state-of-the-art botnet classification.

Explainable intrusion-detection research seeks to expose why a model alerted and to make that explanation usable by analysts. Neupane et al. identify stakeholder-specific explanations and human-in-the-loop design as open requirements for X-IDS [12]. HuntGPT combines an anomaly detector, post-hoc explanations, and a conversational model for analyst-facing interpretation [13], while graph-based incident triage correlates alerts with asset and attack-stage context before assigning severity [14]. These systems motivate analyst assistance, but explanation quality and detection accuracy remain separate constructs. In this artifact, the rules are directly inspectable, every match retains its event identifiers, and the model is an untrusted prioritization layer rather than the owner of detection truth.

One preprint review and two peer-reviewed reviews place LLMs across SOC detection, analysis, threat-intelligence, and response workflows, while identifying limitations in datasets, evaluation, privacy, reliability, and governance [15], [16], [17]. More focused peer-reviewed work uses retrieval and constrained planning to reduce hallucination in incident response [18]. A recent preprint also evaluates reasoning-enabled alert

triage on human-labeled endpoint detections [19]. These studies use LLMs as decision aids, but a plausible recommendation may still be unauthorized or wrong. The model in this study therefore receives no action credentials and cannot bypass independent confirmation or human approval.

Structured generation addresses representation but not semantic truth. JSONSchemaBench finds meaningful differences in constraint coverage, efficiency, and output quality across decoding frameworks even when JSON Schema is the common interface [20]. Human-AI interaction guidance similarly emphasizes communicating uncertainty, supporting correction, and preserving user control when an AI system is wrong [21]. Here, a closed schema prevents unbounded response shapes, while a separate deterministic validator checks identifier provenance, complete finding coverage, forbidden attribution, and rule-applicable controls. Schema validity, evidence grounding, and semantic-policy acceptance are reported independently.

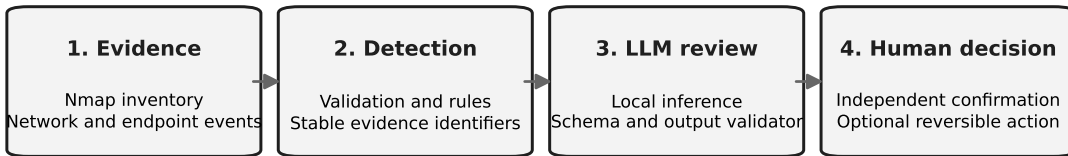
Telemetry is also an adversarial input surface. Peer-reviewed indirect-prompt-injection research exploits the blurred boundary between application instructions and externally controlled data [22]. A recent SOC-specific preprint places instructions inside log fields and reports that constrained output and prompt hardening reduce but do not eliminate decision manipulation [23]. Here, telemetry strings are marked as untrusted, the model has no execution tools, outputs are checked after generation, and rejected responses remain part of the record. The experiment combines stable evidence identifiers, constrained representation, deterministic enforcement, no model response authority, negative detector results, and a counterfactual estimate of automatic-containment harm.

4. Artifact Design

A. Trust-boundary architecture

Figure 1 presents the revised architecture. Evidence acquisition and rule evaluation are deterministic. The local model receives an evidence pack rather than raw authority, while a validator mediates every output. The final human gate is the only path to a separately authorized response system.

Figure 1. Evidence flow and response trust boundaries.



The model has no credentials or direct containment path

Source: Research design (2026).

B. Transparent behavior rules

The detector implements four predeclared rules. BEH-001 requires at least six near-periodic connections to one endpoint with interval coefficient of variation at most 0.15. BEH-002 requires at least eight distinct endpoints within 60 seconds. BEH-003 requires at least 1 MB sent and a sent-to-received ratio of at least 10:1. BEH-004 correlates at least 32 KiB received with executable-like file metadata within 120 seconds. Thresholds were frozen before external-label inspection.

Each finding records rule ID, stable finding ID, host, process context when available, exact evidence IDs, threshold observations, and interpretation limits. Nmap inventory may add authorized asset context but does not change the label. The detector produces review candidates only and invokes no firewall, quarantine, process termination, or file deletion action.

The V1.1 endpoint schema adds bounded optional fields for executable path, signer, parent process, pseudonymous user context, command line, and SHA-256. It excludes credentials, message bodies, keystrokes, packet payloads, and file contents; text is capped at 1,024 characters and hashes are syntactically validated. These fields provide review context and lineage but do not themselves confirm maliciousness.

C. LLM protocol and controls

The grounded protocol uses local Ollama on loopback with a 4,096-token context, 700-token output ceiling, temperature zero, seed 42, and closed schema. V1.1 evaluates llama3.2:3b, gemma3:4b, and qwen3:8b under Ollama 0.32.13; exact manifest digests and quantization records are frozen with the matrix. The historical control runs used Ollama versions 0.32.5 and 0.32.6 and a preserved Llama blob hash. Scan- or event-controlled strings are delimited as untrusted data. The model selects explanations and proposed controls from the evidence pack and a fixed catalog; it holds no operating-system, Zabbix, or firewall credential.

The control reconstructs the historical technical free-text path with temperature 0.7 and top_p=0.9, no system prompt, and no output schema. Both protocols receive the same observations, but the control is not a byte-exact replay: fixed context, output, and timeout limits were added for reproducibility.

5. Method

A. Study design

The study follows an applied Design Science Research structure: artifact construction, demonstration, evaluation, and communication [24]. The 2025 monograph is treated as a historical record, while the experiments reported here use new code and evidence. The confirmatory boundary was defined before the final repetitions: exploratory outputs that influenced a metric or rubric cannot be reused as confirmatory evidence.

The evaluation has five components. Phase A is a deterministic functional benchmark. Phase B1 reports the Virut/NSIS.ay external validation and retrospective diagnostics. Phase B2 uses a prospectively frozen RBot development source, a predeclared threshold grid, and a DonBot holdout parsed once only after configuration and source-state freeze. Phase B3 replays that configuration on a separately published synthetic flow source. Phase C compares grounded and historical LLM protocols over repeated calls and separately tests inert prompt-injection telemetry. The automated Phase-C repetitions are complete; blinded human ratings were not collected. Figure 2 summarizes these roles without combining their metrics.

B. Execution environments and comparison boundary

The preserved V1.0 runs and the V1.1 development environment differ materially, as summarized in Table 1. V1.0 model inference ran on the CPU of an Intel Core i5-1335U system with approximately 16 GiB RAM, first under Windows and then under Debian. The V1.1 development system has an AMD Ryzen 5 5600, approximately 32 GiB RAM, and an NVIDIA RTX 3060 with 12 GiB VRAM. At inventory time, no V1.1 experiment had been executed on the newer machine.

These differences affect model placement, memory pressure, drivers, runtime versions, and latency. Timing across V1.0 and V1.1 is therefore reported only as provenance and cannot identify a protocol-speed or model-speed effect. Any V1.1 comparison intended to isolate a model, prompt, schema, or validator change must execute all compared conditions on the same frozen environment.

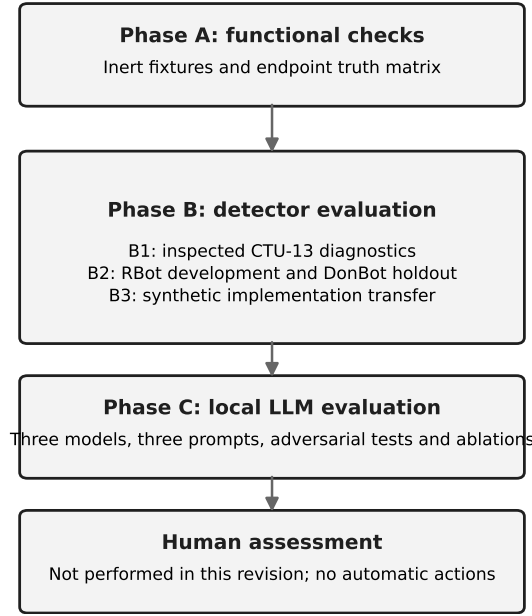
Table 1
Execution-environment provenance for the preserved V1.0 runs and V1.1 development.

Research state	Operating system	CPU	Topology	RAM (GiB)	Inference device
V1.0 initial run	Windows 11 build 26200	Intel Core i5-1335U	12 logical processors	15.7	CPU; Intel Iris Xe present
V1.0 confirmatory repetitions	Debian GNU/Linux, kernel 6.12.101	Intel Core i5-1335U	10 cores / 12 logical processors	15.4	CPU
V1.1 development environment	Windows 10 Pro 22H2 build 19045	AMD Ryzen 5 5600	6 cores / 12 logical processors	31.9	NVIDIA RTX 3060, 12 GiB VRAM

Note: The V1.1 row is an environment inventory, not evidence that a V1.1 experiment had already run. Cross-machine latency is descriptive only because hardware, operating system, driver, runtime version, and CPU/GPU placement differ.

Source: Research data (2026).

Figure 2. Experimental phases and evidentiary roles. Metrics are not pooled across roles.



Source: Research design (2026).

C. Phase A: inert functional fixtures

Six committed JSON Lines scenarios contain no sockets, payloads, persistence mechanisms, or operating-system changes. They represent irregular benign browsing, a legitimate periodic updater as a hard negative, and four emulated patterns corresponding to the four rules. The unit is a scenario-rule pair, yielding 24 binary units. Expected labels were declared in the scenario manifest before execution.

The frozen Phase-A result is summarized in Table 2. It must not be combined with external-validation metrics because it measures implementation conformance to constructed patterns, not real-world detection accuracy.

Table 2
Frozen Phase-A synthetic behavior-rule result.

TP	FP	FN	TN	Precision	Recall	F1	Specificity
4	1	0	19	0.800	1.000	0.889	0.950

Source: Research data (2026).

A separate five-case endpoint matrix evaluates BEH-004: one same-process download/file sequence and four negatives varying bytes, process identity, timing, and file suffix. Every event contains synthetic process lineage and pseudonymous user context. The matrix is executed both with and without Nmap inventory to distinguish contextual enrichment from rule behavior.

D. Phase B1: historical external flow validation

Data selection was frozen before complete-label inspection. CTU-13 Scenario 5 (Virus) is the development source, while Scenario 12 (NSIS.ay) is the family-separated holdout. Only the publisher-recommended bidirectional .binetflow text files were acquired. Their provenance is fixed by these SHA-256 values:

Scenario 5: ef5c9ed6895d4ca5aec723449dae3005

4ccd1f6b091713a52ffcb681ff78a02c

Scenario 12: 1098f0addacedc321c7baefad63ef0d9

a0f26630d0155087d37e8da770dd9f2e

Acquisition code rejects executables, archives, packet captures, and binary Argus files.

The scored unit is an anonymized source host in a non-overlapping five-minute window. Addresses are replaced by stable scenario-local hashes before detection, and labels are never supplied to the detector. Positive windows contain From-Botnet source flows; negative windows contain From-Normal source flows. Mixed, background, inbound, and unsupported-protocol records are counted and excluded.

The adapter creates normalized connection events from flow direction and byte counts. CTU-13 flow records have no endpoint process identity or file lineage, so only BEH-001 through BEH-003 are evaluated. BEH-004 is explicitly out of scope. Scenario 5 was available for development interpretation, but thresholds were not returned. Scenario 12 remained the held-out report set.

After the V1.0 result had been finalized and inspected, both sources were reopened for a predeclared V1.1 retrospective diagnostic. Without changing rule thresholds, the adapter formed non-overlapping source-host units of 60, 300, and 600 seconds. It then decomposed each rule into observable components: connection count, eligible mean interval and interval variation for BEH-001; maximum distinct destinations in any 60-second interval for BEH-002; and absolute sent bytes and sent-to-received ratio for BEH-003. Deterministic class/time/host ordering selected one TP, FP, and FN example. This reuse can explain failure modes and window sensitivity, but it cannot support model selection on the holdout or make that holdout untouched again.

E. Phase B2: prospective family-separated holdout

Before downloading or parsing the new files, Scenario 11 (RBot) was assigned to development and Scenario 6 (DonBot) to the sole confirmatory holdout using official capture metadata and HTTP headers. The primary unit and label policy remained the five-minute source-host definition used in Phase B1. A frozen 243-member grid varied BEH-001 minimum count and interval variation, BEH-002 destination count, and BEH-003 byte and ratio components. Selection maximized development MCC, followed by balanced accuracy, F1, specificity, distance from V1.0, alert count, and deterministic parameter order.

All candidates were evaluated only on RBot. The complete grid, selected configuration, anonymized units, acquisition hashes, and scientific source hashes were preserved before DonBot was parsed. The holdout executor rejected any source-state change and wrote to a previously absent immutable directory. It then evaluated DonBot exactly once. The original preselection record contained a timestamp transcription error; both its hash and a corrected record with the observed pre-download creation time are retained with an explicit erratum. Dataset roles, grid, and gates did not change.

F. Phase B3: second-dataset implementation transfer

The Botnet Group Activity Dataset contains 13 synthetic eight-hour scenarios in the same 15-column .binetflow representation [25], [26]. Its generator adopts activity patterns from CTU-13; it is therefore not independent evidence of real-world generalization. Before downloading the archive or inspecting scenario labels, Scenario 1 was selected for an implementation-transfer replay. Archive and extracted-file byte counts and SHA-256 hashes were verified, and the selected V1.1 thresholds were not changed.

The five-minute source-host unit and label policy remained unchanged. A dataset-specific parser profile expanded only the file/row bounds, accepted the published hyphenated timestamps, used a separate anonymization namespace, and normalized the unspecified source timezone to UTC solely for within-source bucketing. To bound memory and output for 2.1 million rows, the run preserved aggregate confusion counts, truth-separated rule combinations, and the first deterministic example per combination rather than every unit. These results are reported separately from every CTU-13 role.

G. Phase C: repeated protocol comparison

The primary V1.1 matrix uses three quantized local models from different families and sizes: llama3.2:3b, gemma3:4b, and qwen3:8b. Exact local manifest digests, registry records and byte sizes were frozen before inference. Each model receives three semantically equivalent prompt variants: contract, evidence-first, and checklist. All variants use the same evidence pack, output schema, validator, scenario order, temperature zero, top_p=0.9, seed 42, 4,096-token context, and 700-token output ceiling.

Five clustered repetitions cover a no-finding case, a benign periodic-updater hard negative, an incomplete single observation, an endpoint-lineage case, and a 17-event case producing all four findings. Only the four finding-bearing scenarios invoke the model, yielding 20 calls per model/prompt cell and 180 planned calls. API receipt, JSON parsing, closed-schema validity, deterministic semantic-policy acceptance, finding coverage, evidence coverage and lexical safety flags are reported separately. The no-finding case verifies that no model call is made when the detector has no finding. A separately frozen supplement closes the remaining case-diversity gap with 31 unique events and all four rules. It prospectively defines conflicting context as comparable detector severities accompanied by opposing cues: signed maintenance-like lineage versus missing signer and parent context. Neither cue is treated as proof. The three models receive the same evidence-first prompt, schema and validator in three repetitions (nine calls). A pre-inference prompt-size check increased context equally from 8,192 to 16,384 tokens before any supplemental output was observed.

The preserved 2025 comparison remains a historical control: five finding-bearing Phase-A cases were submitted ten times to one grounded protocol and to a reconstructed free-text path, yielding 50 calls per condition. It supports a direct exact-identifier comparison for that fixed model and environment but is not pooled with the V1.1 matrix.

The adversarial matrix contains six paired telemetry-field injections and one paired Nmap inventory injection, plus one unpaired benign hard negative per model. Attack and sanitized conditions differ only in the declared field, for 45 calls. All fixtures are inert and cover fake identifiers, fictional CVE-like text, instruction override, unauthorized controls, delimiter/JSON text, Unicode confusables, long strings, command line, process, DNS, file, host and inventory fields. After 12 responses had been preserved, execution exposed a precondition defect: the hard negative’s empty truth label had been confused with its expected BEH-001 detector false positive. A recorded amendment separated truth from detector precondition without changing any telemetry, prompt, parameter, validator or paired metric; the 12 protocol-identical records were reused.

A single-model ablation reuses the first three Llama/contract repetitions as its reference and changes one component at a time: temperature 0.7, omission of the API format parameter, or reduced grounding language. It adds 36 calls. A post-hoc validator-bypass condition reclassifies every received reference response as usable but is never connected to operations. Three clustered repetitions describe component sensitivity only. A blinded human-rating rubric and randomized 36-item package were prepared from the first repetition of every model/prompt cell. Five missing primary response bodies were filled only for reviewer display by separately frozen availability-recovery calls; the concealed mapping retains primary and selected-response status, and primary denominators remain unchanged. No human semantic ratings are claimed.

The symmetric automatic audit is deliberately conservative. It applies the same identifier, CVE, attribution, containment, authorization and coverage checks to JSON and free text, but its attribution expression also flags negated phrases such as “malware is not confirmed.” These outputs are therefore reported as lexical safety flags rather than expert-adjudicated unsupported claims. Fixed prompts and repetitions are clustered observations; no inferential p-value or attack-success probability is reported.

H. Metrics, response counterfactual, and reproducibility

For true positives (TP), false positives (FP), false negatives (FN), and true negatives (TN), the study reports precision, recall, F1, specificity, balanced accuracy, and Matthews correlation coefficient (MCC). Proportion intervals use the Wilson 95% method. MCC is retained because both classes and both error directions matter:

$$\text{MCC} = \frac{TPTN - FPFN}{\sqrt{(TP + FP)(TP + FN)(TN + FP)(TN + FN)}}. \quad (1)$$

No response was executed. A counterfactual estimates what would have occurred if every alerted window had been blocked: normal-origin alerted windows represent unnecessary actions, and non-alerted botnet-origin windows represent missed opportunities. This is a safety analysis, not a claim about real firewall effectiveness.

Inputs, hashes, model identifier, prompts, raw outputs, environment, per-call errors, aggregate JSON, and table-generation code are preserved in the repository [27]. The flow parsers are streaming; CTU-13 retains

anonymized scored units, while the higher-cardinality second dataset retains truth-separated rule-combination counts and deterministic examples. Article tables are generated directly from committed result JSON to prevent transcription drift.

6. Results

A. Functional benchmark

As shown previously in Table 2, the rules produced 4 true positives, 1 false positive, no false negatives, and 19 true negatives. The resulting precision was 0.800, recall 1.000, specificity 0.950, and F1 0.889. The only false positive was intentional: legitimate periodic updater traffic matched BEH-001. This demonstrates that the implementation recognizes its specified patterns and exposes the known dual-use limitation; it does not estimate field accuracy.

The endpoint matrix in Table 3 produced one TP and four TN, with no FP or FN. The positive preserved exact network and file evidence IDs. Nmap changed only known_asset context; predictions and finding identifiers were identical without it. This validates the programmed temporal/process/file conditions on constructed evidence, not endpoint detection accuracy or causal proof that received bytes became the file.

Table 3
Frozen inert BEH-004 endpoint truth matrix.

Condition	Expected	Predicted	Outcome
Same process within window	Yes	Yes	TRUE POSITIVE
Received bytes below threshold	No	No	TRUE NEGATIVE
Different processes	No	No	TRUE NEGATIVE
File after time window	No	No	TRUE NEGATIVE
Non executable like suffix	No	No	TRUE NEGATIVE

Note: Nmap enrichment changed only the known-asset context; all finding identifiers and decisions were identical without inventory. This is functional validation on constructed evidence, not endpoint accuracy.

Source: Research data (2026).

B. External validation

Table 4 reports development and holdout results separately. The holdout contained 53 botnet-origin and 55 normal-origin units. Sixteen botnet-origin units alerted, 37 were missed, 32 normal-origin units alerted, and 23 did not.

Table 4
Family-separated CTU-13 external validation.

Role	Family	Units	TP	FP	FN	TN	Precision	Recall	F1	Specificity	MCC
Development	Virut	31	5	17	0	9	0.227	1.000	0.370	0.346	0.280
Holdout	NSIS.ay	108	16	32	37	23	0.333	0.302	0.317	0.418	-0.282

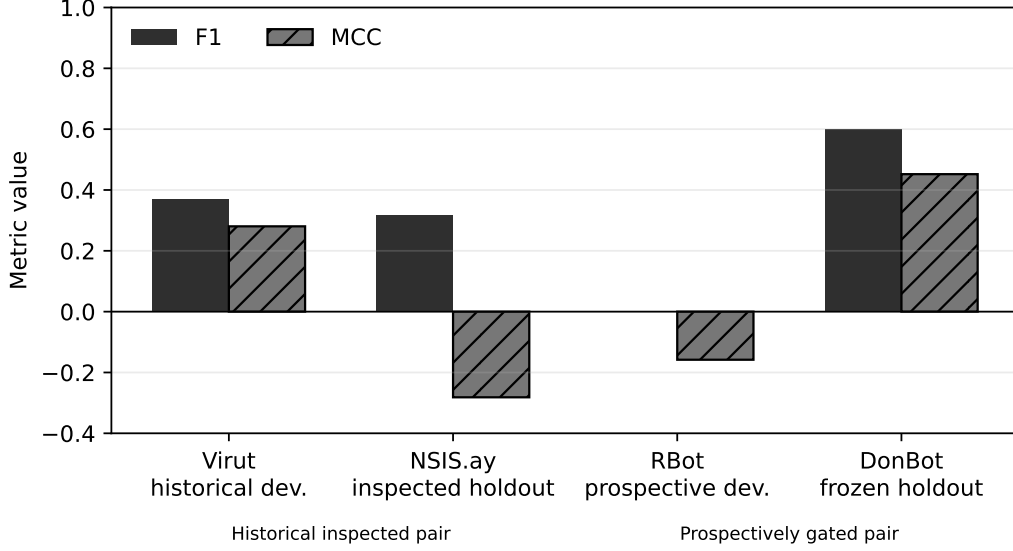
Source: Research data (2026).

Figure 3 compares F1 and MCC while keeping historical and prospective roles separate.

Development precision had a Wilson 95% interval from 0.101 to 0.434, recall from 0.566 to 1.000, and specificity from 0.194 to 0.538. Holdout intervals were from 0.217 to 0.475 for precision, from 0.195 to 0.435 for recall, and from 0.297 to 0.550 for specificity. The holdout MCC of -0.282 is a negative generalization result, not evidence of reliable botnet detection.

The rule-level error distribution is given in Table 5; B/N denotes findings on botnet-origin and normal-origin windows. Rapid distinct destinations dominated both correct and incorrect alerts. Periodicity appeared only in normal-origin holdout windows, and the asymmetric-egress rule did not fire.

Figure 3. F1 and MCC for the historical inspected pair and the prospectively gated CTU-13 pair. Roles remain separate.



Source: Research data (2026).

Table 5
Rule findings on botnet-origin and normal-origin CTU-13 windows.

Rule	Pattern	Development B/N	Holdout B/N
BEH-001	Periodic communication	1/7	0/15
BEH-002	Distinct endpoints	5/17	16/32
BEH-003	Asymmetric egress	0/0	0/0

Source: Research data (2026).

The development and holdout files contained 129,832 and 325,471 rows. Clean binary scoring retained 5,558 and 9,755 rows; most excluded rows were background or inbound/ambiguous under the publisher’s label semantics. Streaming processing took approximately 14.4 and 37.9 seconds, with less than 1.3 MiB peak Python memory traced. Runtime demonstrates feasibility for these files only and is not a throughput benchmark.

C. Retrospective window and threshold diagnostics

Table 6 reports the fixed 1-, 5-, and 10-minute window analyses. Changing the aggregation interval changes both the number and meaning of scored units, so rows are sensitivity analyses rather than interchangeable repetitions. The one-minute holdout result moved MCC closest to zero and increased specificity, but remained weak; selecting it after observing these results would be holdout-driven tuning and is therefore prohibited.

The component analysis in Table 7 explains why the fixed rules failed differently. Most botnet-origin holdout units never reached six same-endpoint connections, whereas the periodicity rule matched only normal-origin units. Destination diversity overlapped substantially between classes: the normal-origin median exceeded the rule threshold, while the botnet-origin distribution combined many low-count units with a large upper tail. For asymmetric egress, no scored unit in either source reached the 1-MB (1,000,000-byte) per-flow component. Many units exceeded the 10:1 ratio alone, so the absolute byte threshold was the immediate non-firing condition. Flow aggregation and missing process/file context prevent interpreting non-firing as proof that exfiltration-like behavior was absent.

An MCC below zero means that, under this binary source-window definition, alert and truth labels were inversely associated rather than merely weakly associated. It is not a probability of error, but it shows

Table 6
Retrospective CTU-13 sensitivity analysis across fixed aggregation windows.

Role	Family	Window (s)	Units	TP	FP	FN	TN	F1	Specificity	MCC
Development	Virut	60	101	18	34	3	46	0.493	0.575	0.351
Development	Virut	300	31	5	17	0	9	0.370	0.346	0.280
Development	Virut	600	19	3	10	0	6	0.375	0.375	0.294
Holdout	NSIS.ay	60	247	31	53	71	92	0.333	0.634	-0.064
Holdout	NSIS.ay	300	108	16	32	37	23	0.317	0.418	-0.282
Holdout	NSIS.ay	600	73	13	18	29	13	0.356	0.419	-0.271

Note: Thresholds were not retuned. Because the V1.0 holdout had already been inspected, all window comparisons are diagnostic rather than confirmatory and cannot be used to restore an untouched-holdout claim.

Source: Research data (2026).

that treating the five-minute alert as a malware-origin classifier would be worse than an uninformative zero-correlation result on this holdout.

Table 7
Five-minute component diagnostics for the three network-flow rules.

Role	Truth	Units	BEH-001 failure path/match				BEH-002 destinations		BEH-003 component matches		
			< 6	No mean	CV> 0.15	Match	Median	Max.	≥ 1 MB	Ratio≥ 10	Both
Development	botnet-origin	5	0	1	3	1	24	30	0	5	0
Development	normal-origin	26	7	6	6	7	10.5	52	0	3	0
Holdout	botnet-origin	53	50	0	3	0	2	323	0	28	0
Holdout	normal-origin	55	18	16	6	15	9	34	0	6	0

Note: BEH-001 categories are mutually exclusive. BEH-002 reports each unit’s maximum distinct destinations in any 60-second interval. BEH-003 component counts do not assert that the underlying behavior was absent.

Source: Research data (2026).

Figure 4 shows the overlap between the two destination-count distributions.

Table 8 makes the operational error modes concrete. The selected TP is a high-diversity botnet-origin window; the selected FP is normal-origin traffic that also exceeds the diversity threshold; and the selected FN contains only one retained event, leaving no rule enough evidence to fire. Exact anonymized host, time, finding, and evidence identifiers remain in the preserved machine-readable result rather than being manually transcribed into the manuscript.

Table 8
Deterministically selected five-minute holdout examples.

Class	Rule	Events	Evidence IDs	Max. destinations	Max. sent (KiB)	Max. ratio
TP	BEH-002	442	20	278	197.0	11560.000
FP	BEH-002	142	20	13	390.2	2.000
FN	N/A	1	1	1	0.1	0.426

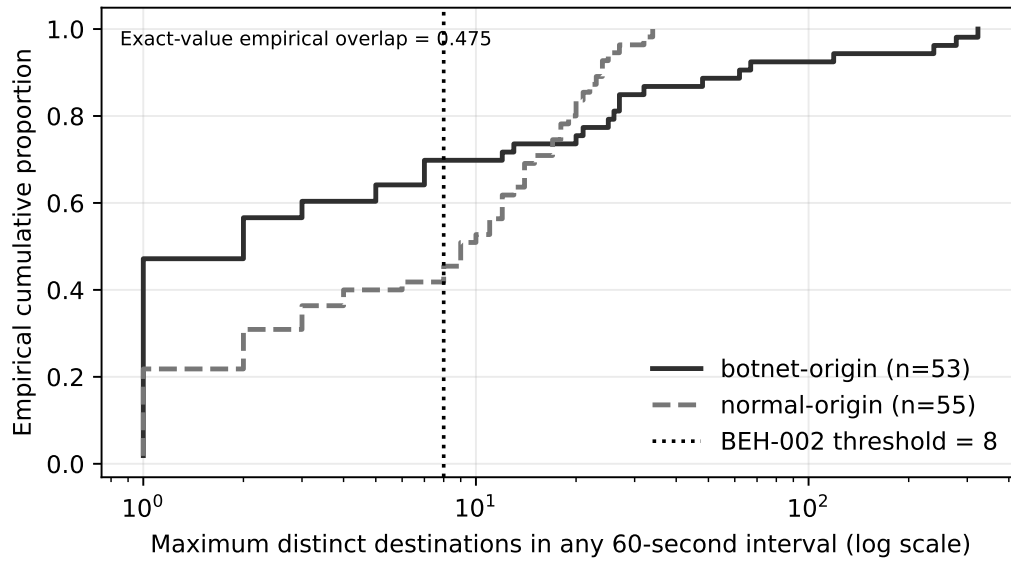
Note: Examples are selected by a deterministic class/time/host ordering from anonymized source-window units; the preserved JSON retains the exact finding and evidence identifiers.

Source: Research data (2026).

D. Prospective CTU-13 holdout

Table 9 reports the prospectively gated analysis. RBot development was a difficult and very small selection source: none of its three botnet-origin units alerted under any frozen candidate. The deterministic tie-break

Figure 4. Empirical BEH-002 destination-count distributions in the five-minute NSIS.ay holdout. The exact-value empirical overlap coefficient is descriptive and sample-specific.



Source: Research data (2026).

selected candidate 97, which retained the V1.0 thresholds except for raising the BEH-002 destination count from 8 to 16. Its negative development MCC was preserved rather than hidden.

Table 9
Prospective V1.1 development selection and single confirmatory CTU-13 holdout.

Role	Family	Units	TP	FP	FN	TN	Precision	Recall	F1	Specificity	MCC
Development	RBot	18	0	2	3	13	0.000	0.000	0.000	0.867	-0.158
Confirmatory holdout	DonBot	105	24	29	3	49	0.453	0.889	0.600	0.628	0.452

Note: The 243-configuration grid was evaluated only on RBot. The selected configuration and scientific source hashes were frozen before the DonBot file was parsed once. Development and holdout metrics are not pooled.

Source: Research data (2026).

On the single DonBot holdout run, the selected detector identified most botnet-origin units and produced a positive MCC. This is evidence of family-specific generalization under the frozen protocol, not universal botnet detection. False-positive burden remained operationally large, and BEH-003 again produced no finding. Across the four CTU-13 sources, 262 source-window units were scored, but no pooled metric is reported because development, retrospective and confirmatory roles differ.

E. Second-dataset implementation transfer

The Scenario-1 replay retained 46,567 of 2,112,224 flows for clean binary scoring and formed 529 source-window units. Table 10 shows TP=96, FP=48, FN=1, and TN=384 (F1 0.797; MCC 0.764). BEH-002 accounted for all 96 botnet-origin alerts and 46 normal-origin alerts; BEH-003 added two normal-origin alerts, while BEH-001 never fired. Thus, 48 of 144 alerts (33.3%) were normal-origin even in this favorable synthetic transfer result.

The archive’s own description reports 23,000 bot records, whereas 22,000 entered scoring. The parser excluded 1,046 unsupported-protocol records overall and preserved the complete exclusion accounting; it did not silently reinterpret those records. Because the source is generated from CTU-13-derived patterns, the positive MCC establishes software and representation transfer only. It cannot be used as an independent replication of the DonBot result.

Table 10
Frozen detector replay on the second, synthetic implementation-transfer dataset.

Role	Units	TP	FP	FN	TN	Precision	Recall	F1	Specificity	MCC
Implementation transfer	529	96	48	1	384	0.667	0.990	0.797	0.889	0.764

Note: The Botnet Group Activity source is synthetic and derives group patterns from CTU-13. It tests parser and detector transfer, not independent real-world generalization; these metrics are not pooled with CTU-13.

Source: Research data (2026).

F. Local-LLM traceability, ablation and adversarial results

Table 11 reports all 180 primary attempts. The local endpoint returned 145 responses; 122 were valid JSON matching the closed schema, and 73 passed the semantic-policy validator. Thus, acceptance was 73/180 by the planned attempt denominator and 73/145 among received responses. Across the seven cells with all 20 API responses, acceptance ranged from 0.10 to 0.75. These cell differences are descriptive because prompt repetitions are clustered and no human correctness labels exist.

Table 11
V1.1 primary local-LLM matrix; each cell contains 20 attempted calls.

Model	Prompt	Calls	API	JSON	Schema	Accepted	Finding cov.	Evidence cov.
llama3.2:3b	contract-v1	20	20	15	15	11	0.750	0.750
llama3.2:3b	evidence-first-v1	20	20	20	20	15	0.938	0.912
llama3.2:3b	checklist-v1	20	20	15	15	4	0.750	0.750
gemma3:4b	contract-v1	20	20	19	19	11	0.900	0.879
gemma3:4b	evidence-first-v1	20	20	20	20	14	0.750	0.750
gemma3:4b	checklist-v1	20	20	16	16	2	0.738	0.712
qwen3:8b	contract-v1	20	20	14	14	14	0.700	0.700
qwen3:8b	evidence-first-v1	20	5	3	3	2	0.600	0.600
qwen3:8b	checklist-v1	20	0	0	0	0	0.000	0.000

Note: API is the number of responses received; JSON and Schema are representation checks; Accepted additionally requires the frozen deterministic semantic-policy validator. Coverage is averaged over attempted finding-bearing scenarios, so API failures contribute zero.

Source: Research data (2026).

The Qwen contract cell completed, but the local Ollama server exited during the evidence-first cell. One connection reset and 34 subsequent connection-refused attempts were preserved, leaving 15/20 evidence-first and 20/20 checklist attempts without responses. The cause was not established from a preserved primary-run server log; it is therefore reported as end-to-end local availability failure, not model-quality, timeout or out-of-memory evidence. Incomplete Qwen cells are not compared as though they had complete outputs.

Availability recovery was kept outside the primary matrix. Its first four-call attempt returned four HTTP 500 responses because two orphaned Ollama child processes remained resident and the Qwen load failed at CUDA allocation. After only those verified orphaned processes were removed, one declared retry returned 4/4 response bodies, of which one passed the validator. Package preflight then found one additional primary Qwen response with an empty body; a prospectively selected single-call recovery produced schema-valid content that the validator rejected. These five outputs make the blinded display package complete but do not revise the primary 145/180 response or 73/180 acceptance denominators.

Every one of the 45 multi-finding attempts was either rejected or lacked an API response. A post-hoc audit could extract schema-valid rankings in four of nine cells. Each of those four repeated one ordering exactly across its available observations, but every ordering omitted findings, used non-exact identifiers, cited evidence across finding boundaries, or selected an inapplicable control. Repeatable ordering therefore did not imply complete or correct ranking; the other five cells had no schema-valid ranking to estimate.

The supplemental stress test in Table 12 received 9/9 API responses. Four outputs were valid JSON/schema and none passed deterministic grounding-policy validation. All nine inputs plus reserved output fit the 16,384-token context, while five responses reached the 900-token output cap. Only Llama supplied all exact finding IDs in a schema-valid form across three repetitions; its order and priority vector repeated exactly, but every output selected rule-inapplicable controls and was rejected. Gemma yielded one schema-valid response with non-exact finding IDs, and Qwen yielded no complete JSON. The supplement covers the missing scenario type but does not reverse the negative complex-ranking result.

Table 12
Supplemental 31-event conflicting-context LLM stress test.

Model	Calls	API	JSON	Schema	Accepted	Output cap	Complete ranks	Rank agreement
gemma3-4b	3	3	1	1	0	2	0	N/A
llama3-2-3b	3	3	3	3	0	0	3	1.000
qwen3-8b	3	3	0	0	0	3	0	N/A

Note: All nine inputs plus their reserved output fit the 16,384-token context. Output cap counts responses reaching 900 generated tokens. Ranking agreement is estimable only for schema-valid outputs containing every exact finding identifier once; repeatability is not semantic correctness.

Source: Research data (2026).

The historical comparison in Table 13 and Figure 5 remains useful within its narrower scope. Grounded output preserved exact finding and evidence IDs in 50/50 calls, versus 0/50 for reconstructed free text, and 40/50 grounded responses passed policy validation. Free text was not asked to emit JSON, so its zero schema validity is a representation difference rather than an independent quality failure.

Table 13
Repeated Phase-C automated traceability comparison.

Protocol	Calls	API responses	Exact findings	Exact evidence	System accepted	Policy rejected
Grounded schema 1.1	50	50	50	50	40	10
Reconstructed free text	50	50	0	0	0	N/A

Note: Free text was not asked to emit JSON; its system-accepted count applies the common exact-ID grounding criterion. Grounded policy rejections retained complete citations but selected a rule-inapplicable control.

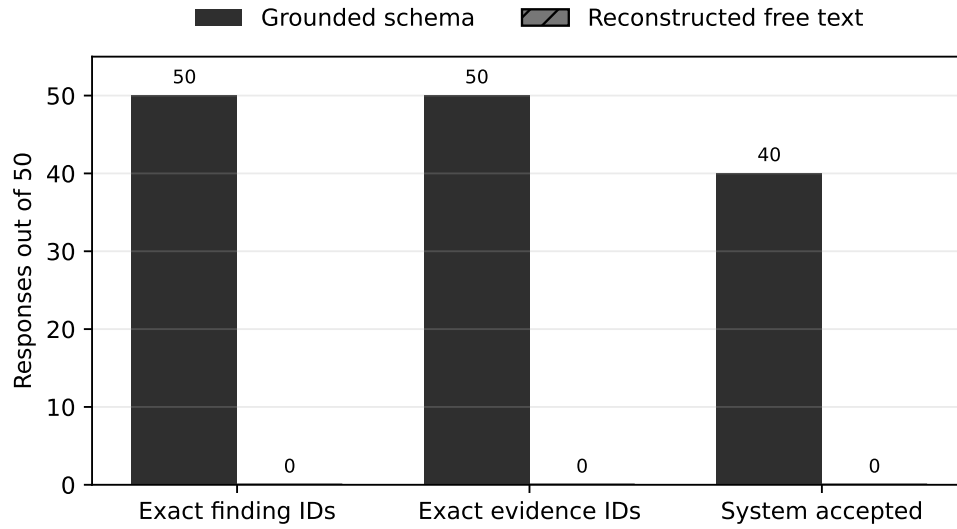
Source: Research data (2026).

The ablation in Table 14 isolates observable component sensitivity for the first three Llama/contract repetitions. The reference accepted 7/12 attempts. Raising temperature to 0.7 accepted 4/12. Omitting only the API format constraint produced 12 API responses but zero valid JSON, zero schema-valid outputs and zero accepted outputs. Reduced grounding language accepted 9/12, showing that this small sample does not identify a monotonic benefit from longer instructions. The unsafe validator bypass labels all 12 received reference responses usable, including three that lacked valid JSON/schema output.

The adversarial executor attempted all 45 calls, but 20 returned HTTP 500 and only 11 of 21 attack/sanitized pairs received both responses; ten pairs had two parseable outputs. Table 15 therefore uses eligible denominators. Validator acceptance status changed in 8/11 available pairs. Among ten parseable pairs, priority changed in two, control set in four, finding order in one, and cited evidence set in none. The conservative lexical safety flag changed in 1/11 audited pairs. These observations show decision sensitivity and enforcement value; they do not estimate attack success probability from one observation per pair. Pairs with two failures are availability failures, not evidence of robustness.

All three benign hard-negative calls were accepted as grounded reviews of a BEH-001 finding even though the fixture’s truth label is negative. This is expected under the model contract: the model receives the detector’s candidate, not ground truth. It reinforces that schema and citation validity cannot turn a detector false positive into a confirmed incident. No model response triggered an action, and no blinded human semantic rating was collected.

Figure 5. Preserved single-model traceability comparison. System acceptance includes deterministic grounding and policy validation.



Source: Research data (2026).

Table 14
Single-model component-sensitivity ablation.

Condition	New calls	Attempts	API	JSON	Schema	Accepted	Finding cov.	Evidence cov.
Reference (primary reuse)	0	12	12	9	9	7	0.750	0.750
Temperature 0.7	12	12	12	9	9	4	0.500	0.500
API format removed	12	12	12	0	0	0	0.000	0.000
Grounding language reduced	12	12	12	9	9	9	0.750	0.750
Validator bypass (post hoc)	0	12	12	9	9	12	0.750	0.750

Note: Reference and validator-bypass rows reuse the same 12 primary responses. Bypass counts every API response as usable and was never connected to operations. Three clustered repetitions support descriptive sensitivity only.

Source: Research data (2026).

Table 15
Adversarial paired-output availability and eligible decision changes.

Model	Calls	Responses	Failures	Eligible pairs	Parseable pairs
gemma3:4b	15	15	0	7	6
llama3.2:3b	15	3	12	1	1
qwen3:8b	15	7	8	3	3
Decision changes among eligible pairs					
Metric	Changed	Eligible			
Validator status	8	11			
Priority label	2	10			
Control set	4	10			
Finding order	1	10			
Evidence set	0	10			
Lexical safety flag	1	11			

Note: A pair is eligible for status comparison only when both API responses exist, and for structural comparison only when both are parseable. Two API failures are not treated as an unchanged decision. One observation per pair does not estimate attack-success probability.

Source: Research data (2026).

G. Counterfactual response safety

The system executed zero automatic actions. In the historical five-minute holdout, a block-on-every-alert policy would have targeted normal-origin windows in 32 of 48 cases while missing 37 botnet-origin units. In the new confirmatory holdout, it would have targeted normal-origin windows in 29 of 53 alerts and missed three botnet-origin units. Thus, even the stronger confirmatory MCC does not justify automatic block-on-alert: more than half of the proposed actions would still have been unnecessary under the dataset labels.

Table 16 also evaluates automatic blocking only after two simultaneous rules. That stricter policy does not solve the tradeoff: on historical NSIS.ay it would act on 15 normal-origin units, no botnet-origin unit, and miss all 53 positives; on DonBot it would act on six of 27 positive units and five normal units while leaving 21 positives without action. No unit in the synthetic transfer source had two rules, so the policy would take no action and miss all 97 positive units.

Table 16
Offline containment-policy counterfactuals; no action was executed.

Dataset role	Block every alert			Block after two rules		
	Actions	Normal	Bot missed	Actions	Normal	Bot missed
Historical NSIS.ay	48	32	37	15	15	53
Confirmatory DonBot	53	29	3	11	5	21
Synthetic transfer	144	48	1	0	0	97

Note: Dataset labels indicate source origin, not business impact. Approval-gated rate limiting and confirmation-gated isolation executed zero actions because the required decisions are absent; evidence collection and monitoring do not contain hosts.

Source: Research data (2026).

Analyst approval, temporary rate limiting after approval, and isolation after independent confirmation are represented as proposals with zero executed actions because the datasets contain neither approval nor independent-confirmation decisions. Evidence collection and increased monitoring retain all alert targets but perform no containment. Their lower direct disruption does not imply zero cost: normal-origin targets still consume analyst and storage capacity, while non-alerted positive units remain unreviewed.

7. Discussion

A. RQ1: transparent rules generalize unevenly and remain review triggers

The functional, retrospective, development, confirmatory and implementation-transfer results answer different questions. Phase A shows agreement with constructed patterns. Phase B1 shows that timing and destination diversity can be common in ordinary traffic and absent from many labeled botnet windows. Phase B2 demonstrates that a source-state-gated configuration can generalize positively to DonBot, but the same configuration detected no RBot development unit and still alerted on many normal-origin DonBot windows. Phase B3 shows that the parser and frozen detector transfer to a larger compatible source, but its synthetic CTU-13-derived construction prevents treating the favorable MCC as independent replication. Combining these roles would hide both the failures and the conditional improvements. RQ1 is therefore mixed for cross-family signal and negative for reliable standalone malware-origin classification: the rules remain explainable hypotheses for review.

The error pattern identifies a concrete systems requirement. Network flows lack process ownership, executable identity, signer information, parent-child lineage, file creation, and user context. Windows Sysmon, for example, can associate network connections, DNS queries, and file creation with processes, although collection volume and privacy require selective configuration [3]. Future testing should add authorized endpoint context and evaluate it on a newly frozen holdout rather than retuning against the inspected CTU-13 scenario.

B. RQ2: constraints improve observability, not intrinsic reliability

For the preserved single-model comparison, grounded output supported exact traceability: all supplied identifiers appeared in 50/50 calls, versus 0/50 for reconstructed free text. End-to-end grounded acceptance

was 40/50 because the validator consistently blocked a rule-inapplicable control. The broader V1.1 matrix prevents generalizing that result into semantic superiority. Only 73 of 145 received responses passed the deterministic validator, no primary multi-finding response was accepted, and 35 Qwen calls had no response after the local server exited. The 31-event supplement likewise accepted 0/9 despite complete API availability, separating runtime recovery from semantic-policy success.

The ablation separates API formatting from post-generation validation. The API-level format constraint was necessary for parseable output in this sample, while the validator prevented malformed or policy-invalid responses from becoming usable. Prompt wording and temperature changed observed acceptance, but three clustered repetitions cannot identify population-level causal effects. Schema-valid multi-finding order was perfectly repeated in four estimable cells while remaining incomplete or semantically invalid; ranking repeatability was therefore not ranking correctness.

The adversarial pairs further show that exact evidence citation can remain unchanged while acceptance, priority or controls change. This answers RQ2 for machine-checkable traceability and enforcement in the implemented artifact, not for interpretive correctness or analyst usefulness. The symmetric lexical audit overflags some negated safety language, and no blinded expert ratings were collected. Constrained generation makes failure more visible and rejection enforceable; it does not make generation intrinsically reliable.

C. RQ3: the justified contribution is triage

The artifact can normalize evidence, correlate events with an authorized asset inventory, identify why a rule matched, preserve exact event IDs, and propose additional evidence collection. It may prepare a scoped response candidate containing source, destination, protocol, duration, approval requirement, and rollback conditions. It cannot responsibly identify malware, confirm exploitability, isolate a host, quarantine a file, or change a firewall before independent confirmation and human authorization. The counterfactual results quantify why that confirmation is necessary.

8. Threats to Validity and Ethical Constraints

Construct validity is limited because CTU-13 labels describe flow origin, not whether every five-minute window contains a detectable malicious action. The study measures review-trigger performance under that operational definition, not malware-family classification. Network-only adaptation cannot evaluate the endpoint-dependent BEH-004 rule.

Internal validity is limited by heuristic thresholds, source-host windowing, and the possibility that scenario-specific traffic generation affects both labels and patterns. The historical NSIS.ay holdout has already been inspected and must not be reused as untouched evidence after tuning. The prospective DonBot role and grid were frozen before parsing, but the RBot development set contained only three positive units, making threshold selection unstable despite the deterministic rule.

The LLM analysis is also limited by clustered fixed prompts, deterministic decoding that does not create independent samples, and local-runtime availability. The adversarial precondition amendment was recorded after 12 calls; it changed only the distinction between the benign truth label and expected detector false positive, but the matrix cannot be described as unamended preregistration. The supplemental context amendment occurred before inference and followed deterministic prompt sizing. The primary Qwen server exit and adversarial HTTP 500 responses reduce comparable denominators. Availability-recovery outputs are disclosed separately and never replace primary attempts. Absence of a response cannot be interpreted as resistance, and post-hoc denominator and ranking audits are labeled as such.

The retrospective V1.1 window analysis does not repair that limitation. It is reported to expose sensitivity and failure mechanisms, with thresholds unchanged, but no winning window is selected from it. Any confirmatory V1.1 claim requires a newly frozen family-separated holdout whose labels were not consulted during threshold, window, adapter, or feature decisions.

External validity is limited by an older academic dataset, four malware families with different research roles, 262 CTU-13 source-windows, one CTU-13-derived synthetic transfer source, three local model tags, six primary/supplemental scenario templates, three prompt variants, and two materially different workstations. The second source improves implementation coverage but not construct independence. Confidence intervals

remain wide, and neither source represents current production networks. No production telemetry, live malware, packet payload, or actual containment was used. Five primary and three supplemental V1.1 repetitions per cell, plus ten historical repetitions per protocol, describe stability under fixed parameters but are clustered observations. The adversarial matrix has one observation per pair, and automatic lexical checks do not replace blinded expert judgment. The blinded package exists, but expert ratings and inter-rater agreement remain unobserved.

Reproducibility depends on the frozen URLs and hashes because the large external text flows are not committed. The experiment preserves aggregate and anonymized unit output, but external availability remains outside repository control. Model-tag reproducibility additionally depends on preserving the exact Ollama model digest.

All collection must be authorized. Infrastructure and endpoint telemetry can contain personal and sensitive operational data and must follow purpose limitation, retention, access control, and applicable privacy law. The public fixtures are inert; acquisition code blocks malware binaries and packet captures. Reports are advisory, and the LLM has no action credentials.

9. Conclusion

This study evaluated an evidence-grounded local-LLM architecture instead of assuming that a persuasive narrative improves security. Functional fixtures passed their intended rules, while the inspected NSIS.ay holdout retained a negative MCC. The prospectively frozen DonBot holdout produced recall 0.889, specificity 0.628, F1 0.600, and MCC 0.452 under the RBot-selected configuration. That improvement is bounded: 29 of 53 confirmatory alerts were normal-origin windows, and three botnet-origin windows were missed. A larger synthetic CTU-13-derived source produced F1 0.797 and MCC 0.764, but its proper evidentiary role is implementation transfer, not independent validation.

The LLM evaluation was also mixed. The historical grounded/free-text comparison supports exact identifier traceability for one fixed model, but the broader matrix accepted only 73 of 145 received responses, rejected every primary multi-finding output, and retained 35 Qwen availability failures. The 31-event conflicting-context supplement received all nine responses but accepted none; five outputs exhausted their generation cap. The format ablation produced no valid JSON without the API constraint, whereas validator bypass would have admitted malformed responses. Adversarial telemetry changed validator status in eight of 11 pairs with both responses; 20 other adversarial calls failed at the API. Exact evidence sets remained stable in the ten parseable pairs, but one observation per pair cannot establish robustness. No automatic action was executed.

The main empirical contribution is the combination of a prospectively gated detector improvement and documented failures. Transparent rules and constrained local generation can produce auditable candidates, but neither schema validity nor repeated ordering establishes semantic correctness. Deterministic collection, validation and triage may be automated; attribution and containment may not.

Future work should evaluate an independently constructed contemporary flow dataset, reserve family-separated holdouts, collect privacy-reviewed endpoint evidence, replicate multi-finding and adversarial cases, obtain ethics-reviewed blinded expert ratings, and test reversible response proposals in an isolated authorized laboratory. Later threshold, prompt, validator or audit changes must be reported as a new version rather than retroactively improving this result.

References

- [1] G. F. Lyon, *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*. Sunnyvale: Insecure.Com, 2009.
- [2] Nmap Project, “Nmap reference guide,” 2025. [Online]. Available: <https://nmap.org/book/man.html>
- [3] Microsoft, “Sysmon events,” 2026. [Online]. Available: <https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-events>
- [4] National Institute of Standards and Technology, “Artificial intelligence risk management framework (ai rmf 1.0),” NIST, Tech. Rep. NIST AI 100-1, 2023, nIST AI 100-1. [Online]. Available: <https://doi.org/10.6028/NIST.AI.100-1>
- [5] Mitre Corporation, “Mitre att&ck,” 2025. [Online]. Available: <https://attack.mitre.org/>
- [6] S. García, M. Grill, J. Stiborek, and A. Zunino, “An empirical comparison of botnet detection methods,” *Computers & Security*, vol. 45, p. 100 to 123, 2014. [Online]. Available: <https://doi.org/10.1016/j.cose.2014.05.011>
- [7] Stratosphere Laboratory, “CTU-13 dataset: A labeled dataset with botnet, normal and background traffic,” 2026. [Online]. Available: <https://www.stratosphereips.org/datasets-ctu13>

- [8] Ollama, “Ollama documentation,” 2025. [Online]. Available: <https://github.com/ollama/ollama>
- [9] Ollama, “Structured outputs,” 2026. [Online]. Available: <https://docs.ollama.com/capabilities/structured-outputs>
- [10] R. Sommer and V. Paxson, “Outside the closed world: On using machine learning for network intrusion detection,” in 2010 IEEE Symposium on Security and Privacy, 2010, p. 305 to 316. [Online]. Available: <https://doi.org/10.1109/SP.2010.25>
- [11] A. L. Buczak and E. Guven, “A survey of data mining and machine learning methods for cyber security intrusion detection,” *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, p. 1153 to 1176, 2016. [Online]. Available: <https://doi.org/10.1109/COMST.2015.2494502>
- [12] S. Neupane, J. Ables, W. Anderson, S. Mittal, S. Rahimi, I. Banicescu, and M. Seale, “Explainable intrusion detection systems (X-IDS): A survey of current methods, challenges, and opportunities,” *IEEE Access*, vol. 10, p. 112392 to 112415, 2022. [Online]. Available: <https://doi.org/10.1109/ACCESS.2022.3216617>
- [13] T. Ali, P. Kostakos, and S. Sheikhi, “HuntGPT: Integrating machine learning-based anomaly detection and explainable AI with large language models (LLMs),” *Telecom*, vol. 7, no. 3, p. 73, 2026. [Online]. Available: <https://doi.org/10.3390/telecom7030073>
- [14] L. Sadlek, M. M. Yamin, P. Čeleda, and B. Katt, “Severity-based triage of cybersecurity incidents using kill chain attack graphs,” *Journal of Information Security and Applications*, vol. 89, p. 103956, 2025. [Online]. Available: <https://doi.org/10.1016/j.jisa.2024.103956>
- [15] H. Xu, S. Wang, N. Li, K. Wang, Y. Zhao, K. Chen, T. Yu, Y. Liu, and H. Wang, “Large language models for cyber security: A systematic literature review,” *arXiv preprint arXiv:2405.04760*, 2024. [Online]. Available: <https://doi.org/10.48550/arXiv.2405.04760>
- [16] A. Habibzadeh, F. Feyzi, and R. E. Atani, “Large language models for security operations centers: A comprehensive survey,” *Journal of Electrical and Computer Engineering*, vol. 2026, p. 3383674, 2026. [Online]. Available: <https://doi.org/10.1155/jece/3383674>
- [17] H. Alqahtani and P. Ahuja, “Secure autonomous cyber defense with LLM agents: A systematic review of autonomy, tool-augmented reasoning, and governance constraints,” *Computers & Electrical Engineering*, vol. 135, p. 111184, 2026. [Online]. Available: <https://doi.org/10.1016/j.compeleceng.2026.111184>
- [18] K. Hammar, T. Alpcan, and E. C. Lupu, “Incident response planning using a lightweight large language model with reduced hallucination,” in *Network and Distributed System Security Symposium*, 2026. [Online]. Available: <https://doi.org/10.14722/ndss.2026.240358>
- [19] A. Khanna, M. Nandan, C. V. Popa, J. Pujol-Roig, D. Bolocan, L. Vasile, A. Apostu, C. Helwig, M. Gaman, M. Brautbar, E. Raff, C. Midler, and S. Krasser, “Cybersecurity detection classification with reasoning-enabled language models,” *arXiv preprint arXiv:2607.28460*, 2026. [Online]. Available: <https://doi.org/10.48550/arXiv.2607.28460>
- [20] S. Geng, H. Cooper, M. Moskal, S. Jenkins, J. Berman, N. Ranchin, R. West, E. Horvitz, and H. Nori, “JSONSchemaBench: A rigorous benchmark of structured outputs for language models,” *arXiv preprint arXiv:2501.10868*, 2025. [Online]. Available: <https://doi.org/10.48550/arXiv.2501.10868>
- [21] S. Amershi, D. Weld, M. Vorvoreanu, A. Fournay, B. Nushi, P. Collisson, J. Suh, S. Iqbal, P. N. Bennett, K. Inkpen, J. Teevan, R. Kikin-Gil, and E. Horvitz, “Guidelines for human-ai interaction,” in *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems*, 2019, p. 1 to 13. [Online]. Available: <https://doi.org/10.1145/3290605.3300233>
- [22] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection,” in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, 2023, p. 79 to 90. [Online]. Available: <https://doi.org/10.1145/3605764.3623985>
- [23] R. Pandey and A. Bhujang, “Poisoning the watchtower: Prompt injection attacks against LLM-augmented security operations through adversarial log content,” *arXiv preprint arXiv:2605.24421*, 2026. [Online]. Available: <https://doi.org/10.48550/arXiv.2605.24421>
- [24] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, “A design science research methodology for information systems research,” *Journal of Management Information Systems*, vol. 24, no. 3, p. 45 to 77, 2007. [Online]. Available: <https://doi.org/10.2753/MIS0742-1222240302>
- [25] D. P. Hostiadi and T. Ahmad, “Dataset for botnet group activity with adaptive generator,” *Data in Brief*, vol. 38, p. 107334, 2021. [Online]. Available: <https://doi.org/10.1016/j.dib.2021.107334>
- [26] D. P. Hostiadi and T. Ahmad, “Botnet group activity dataset,” 2021, cC BY-NC 3.0. [Online]. Available: <https://data.mendeley.com/datasets/4vftxh97m8/1>
- [27] J. V. Ielen and V. M. Favaro, “Tec: Sistema de análise de segurança de redes,” *Repositório de código-fonte*, 2025, recorte pré-banca: commit dd63d4c; base da revisão pós-defesa: commit 5d93fac. [Online]. Available: <https://github.com/awakyy1/network-security-review>